PlayStake Master Compliance Manual

Operator	[COMPANY NAME] (company no. [REG NO]), trading as PlayStake
Registered office	[REGISTERED ADDRESS]
Website	playstake.org
Licence applied for	Remote operating licence — betting intermediary (peer-to-peer wagering on skill-based games). *To be confirmed with legal advisers before submission.*
Document owner	[COMPLIANCE LEAD NAME], Head of Compliance and Money Laundering Reporting Officer (MLRO)
Approved by	[COMPLIANCE LEAD NAME], for and on behalf of the board
Version	0.1 — draft for licence application
Effective date	[DATE OF APPROVAL]
Next review	12 months from approval, or sooner on a material change (see section 7)

> **Draft status.** This manual and the policies it indexes were prepared from the PlayStake platform as built on 30 September 2026. They describe controls that exist in the software today, and they flag clearly where something still depends on a contract, a person or a decision. Before submission, they must be reviewed by a qualified gambling-compliance adviser or solicitor. They must also be checked against the Gambling Commission's Licence Conditions and Codes of Practice (LCCP) and guidance current at that time, as requirements are updated frequently. Paragraph references to the LCCP are given for orientation and must be confirmed.

---

1. Purpose and scope

This manual is the top-level description of how PlayStake meets the licensing objectives in section 1 of the Gambling Act 2005:

1. preventing gambling from being a source of crime or disorder, being associated with crime or disorder, or being used to support crime;
2. ensuring gambling is conducted in a fair and open way;
3. protecting children and other vulnerable persons from being harmed or exploited by gambling.

It applies to every person who works for or on behalf of PlayStake, including directors, employees, contractors and outsourced providers. It also covers every part of the PlayStake service: the website at playstake.org, the lobby and challenge system, streamed matches refereed through Kick, the demo and skill games at /play, payments and withdrawals, and all back-office tooling.

2. The business in brief

PlayStake is a peer-to-peer platform where adult customers wager against each other on the outcome of skill-based games they play themselves:

- **Opponents are other customers.** PlayStake never takes the other side of a bet. It holds both stakes in escrow and pays the winner. It earns a platform fee (a percentage of the pot) on settled matches.
- **Match types.**
  - *Lobby matches* are played in PlayStake's own games (darts, tic-tac-toe). The server decides the result.
  - *Streamed matches* are played in third-party games while both players broadcast on Kick. An independent, approved human referee watches both streams and records the result, and every referee action is written to a tamper-evident, hash-chained audit trail.
- **Money.** All money moves through a double-entry ledger with a per-match escrow account. The ledger is audited automatically every night.
- **Disputes.** Either player can dispute a result before it pays out. Payout pauses while the dispute is reviewed.

This business model shapes the risk profile, which is covered in detail in the AML Risk Assessment (Policy 07):

- **Main crime risk.** Two customers could pass money between themselves by one deliberately losing ("chip dumping").
- **Main integrity risk.** A result could be manipulated.
- **Main harm risks.** Loss-chasing and spending beyond one's means are amplified by play that is fast and competitive.

3. Governance and key people

PlayStake is a small operator at launch. One person currently holds all the key compliance roles:

Role	Holder	Responsibilities
Head of Compliance	[COMPLIANCE LEAD NAME]	Owns this manual and all policies. Monitors regulatory change. Reports to the board. Is the point of contact for the Gambling Commission.
Money Laundering Reporting Officer (MLRO)	[COMPLIANCE LEAD NAME]	Owns the AML risk assessment. Decides AML cases. Makes Suspicious Activity Reports (SARs) and Defence Against Money Laundering (DAML) requests to the NCA.
Customer Interaction / Safer Gambling Lead	[COMPLIANCE LEAD NAME]	Owns harm-signal review, customer interactions and the effectiveness evaluation.
Complaints Manager	[COMPLIANCE LEAD NAME]	Owns the complaints procedure. Issues final responses. Is the liaison with IBAS.
Personal Management Licence holders	[NAMES]	As required by the Commission for the specified management offices.

Segregation of duties. The Commission expects key functions, especially the MLRO, to be sufficiently senior, independent and resourced. While one person holds every role, PlayStake uses four compensating controls:

1. **Audit trail.** Every privileged action is written to an append-only admin audit log that the database itself protects from edits or deletion.
2. **Independent review.** An external compliance adviser, [ADVISER NAME / FIRM], reviews a sample of AML cases, harm-signal decisions and complaints every quarter.
3. **Built-in safeguards.** The software enforces the most important rules itself, so they don't depend on one person's judgement. For example:
   - age cannot be marked verified without an approved adult identity document
   - staff cannot change their own role
   - self-exclusion cannot be lifted early by anyone
   - staff can only ever lower a customer's deposit limit
4. **Separation as we grow.** Separate role holders will be appointed as the business grows, starting with the MLRO, and before monthly customer deposits exceed [THRESHOLD].

Board oversight. The board receives a compliance report every quarter covering:

- AML case volumes and outcomes, and any SARs made (numbers only)
- harm signals raised and the outcomes of interactions
- complaints: volumes, timeliness, outcomes and IBAS referrals
- ledger audit results
- any regulatory incidents or key-event notifications

4. The policies

No.	Policy	What it covers	Main controls in the platform
01	Crime Prevention and Fraud Controls	Account security, multi-accounting, collusion and match integrity, payment fraud, staff controls	2FA (required for staff), rate limits and lockouts, identity screening, head-to-head match cap, referee audit chain, double-entry ledger with nightly audit, chargeback suspension, append-only admin audit log
02	Complaints Procedure and ADR	How complaints are received, handled and escalated to IBAS	Reference numbers, immediate acknowledgement, 8-week deadline tracking with alerts, final-response letters naming IBAS
03	Self-Exclusion	Customer-requested self-exclusion and cool-off	6-month to 5-year exclusion, no early lifting, positive action plus 24-hour cooling-off to return, open activity withdrawn, marketing stopped, exclusion follows the person
04	Multi-Operator Self-Exclusion (GAMSTOP)	Participation in the national scheme	GAMSTOP checks at identity verification, login and before any deposit or stake; fails closed

No.	Policy	What it covers	Main controls in the platform
05	Customer Interaction and Harm Prevention	Identify, act and evaluate	Five automated harm markers, immediate in-app interaction, staff review queue, operator limits and cool-offs, 14-day outcome evaluation, deposit-limit prompt before first deposit, reality checks
06	Age Verification	Keeping under-18s out	Date of birth and 18+ confirmation at sign-up, document KYC before any deposit, free-to-play access or gambling, under-18 closure process
07	AML Risk Assessment and Controls	Money laundering and terrorist financing	Risk assessment, KYC, transaction monitoring (chip dumping, shared IPs, deposit-and-withdraw-without-play, EDD threshold), withdrawal holds, case management, SAR process

The application's technical documents:

No.	Document	What it covers
08	System Diagram and Outsourcing Map	Every component and supplier, with commentary: payments, identity, geolocation, marketing, customer service, fraud detection, hosting
09	End-to-End Customer and System Flow	Registration to gambling to payout, with the checks at each step and where the equipment is
10	Operational Model Map	Location, provider and operator of every system and activity, including key equipment
11	Testing Strategy	Test-house scope (RNG, game rules), in-house testing, CI, change control, annual security audit
12	RTS Compliance Statement and Change Register	How each applicable RTS is met, RTS 12 phase 1 and 2, and how RTS changes are tracked
13	Information Security Policy	ISO/IEC 27001:2022 control mapping for the RTS security requirements, residual risks and gaps
14	Incident Response and Key Event Reporting	Triage, response, customer and ICO notification, LCCP 15.2.1 key events within 5 working days
15	UAE (GCGRA) Certification Plan	Route to GCGRA licensing and GLI-19 / GLI-33 certification with GLI or BMM (planning draft, unverified)
16	Payment Services and Payment Methods	Payments only through PSR-authorised providers; approved methods fixed in code; provider register and onboarding checklist
17	DPIA: Identity Verification (Didit)	Biometric identity checks: lawful basis, necessity, risks and controls, questions for Didit (first draft)

Each policy states its owner, its review date, the LCCP provisions it addresses, and exactly how the platform carries it out.

5. Cross-cutting controls

These controls support every policy.

5.1 One eligibility check in front of all gambling

Every deposit, every stake, and every entry to the games (including free-to-play) passes through a single check in the platform. It fails closed and checks, in order:

1. the account is **active**, not suspended or closed
2. the customer's **age and identity are verified**
3. they are **not registered with GAMSTOP**
4. they have **no cool-off or self-exclusion in force**

Withdrawals are deliberately outside this check. A self-excluded or GAMSTOP-registered customer can always take their money out.

5.2 Records and retention

- **Protected records.** Identity documents, self-exclusions and breaks, harm signals, customer interactions, complaints, AML cases and the admin audit log are all kept when a user record is deleted. The database refuses the deletion.
- **Identity documents.** These are encrypted at rest with AES-256-GCM and decrypted only when a reviewer deliberately opens one.
- **Retention periods.** The retention schedule is set out in the Privacy Policy. Financial, dispute, referee, AML and complaint records are kept for at least 5 years after the customer relationship ends, which meets the record-keeping expectation for AML purposes. **Outstanding:** an automated purge for records past their retention period is not yet built (see section 8).

5.3 Staff access

- **Role-based access.** Admin tools are restricted to the ADMIN role, checked on the server for every request.
- **Two-factor authentication.** Staff must use 2FA to reach admin tools in production.
- **Audit log.** Every privileged change is recorded in the append-only admin audit log: who, what, when, from which IP address, and why. This includes:
  - role and KYC changes
  - account suspensions and closures
  - KYC decisions
  - dispute resolutions
  - complaint handling
  - harm-signal actions
  - AML decisions
- **Viewing the log.** Staff can read the log at /admin/audit-log.

5.4 Training

All staff complete training before gaining access to customer data or admin tools, and refresh it every year. It covers:

- this manual

- AML and the tipping-off offence
- safer gambling and customer interaction
- complaints handling
- data protection

Completion is recorded in [TRAINING RECORD LOCATION].

5.5 Alerts

The platform emails the compliance inbox, [COMPLIANCE EMAIL] (configured as `EMAIL_ADMIN`), when:

- an AML case is opened
- a harm signal is raised
- an interaction has no effect
- a complaint is two weeks from, or past, its 8-week deadline
- the nightly ledger audit fails
- the anomaly scan detects unusual patterns on PlayStake's own games

> **Important:** without `EMAIL_ADMIN` set these alerts are silently skipped. Setting it is a go-live requirement.

6. Regulatory reporting and notifications

The Head of Compliance keeps a calendar of regulatory returns and notifications, and is responsible for them:

- **Regulatory returns** to the Gambling Commission, submitted quarterly.
- **Key event notifications**, sent within the timescales in LCCP licence condition 15.2. These include:
  - a breach of the ledger's integrity
  - a significant security incident
  - a change of ADR provider
  - the appointment or departure of key people
- **Suspicious Activity Reports** to the NCA (see Policy 07). The Commission is told where the LCCP requires it.
- **Personal data breaches** reported to the ICO within 72 hours where required.

7. Review and change control

- **Scheduled review.** Every policy is reviewed at least once a year.
- **Earlier review.** A policy is also reviewed straight away after any of the following:
  - a new product, game type, payment method or technology
  - a material change in customer behaviour or risk indicators
  - a regulatory change
  - a significant incident or complaint trend

    - a finding from the quarterly independent review
- **Version control.** Changes are recorded in each document's version history and approved by the Head of Compliance and the board.
- **Code as documentation.** The platform's code is the operative description of each control. Any change to a compliance control in the code must reference the policy it implements and be reviewed by the Head of Compliance before release.

8. Outstanding items before submission

These must be done before the application is submitted, or before real-money launch as marked. Each is also noted in the relevant policy.

#	Item	Needed for	Owner
1	Complete company details, key people and PML holders throughout these documents	Application	[COMPLIANCE LEAD NAME]
2	Sign the ADR agreement with IBAS and confirm the referral terms. The site and emails state 6 months from the final response, which must be confirmed.	Application	Complaints Manager
3	Join GAMSTOP, then set `GAMSTOP_API_KEY` and `GAMSTOP_REQUIRED=true` in production. Also confirm field requirements: collecting a mobile number may improve match rates.	Launch	Head of Compliance
4	~~Appoint an electronic identity and age verification provider~~ Didit appointed and integrated (October 2026). Remaining: sign the DPA, confirm data locations, complete the DPIA (Document 17), switch from sandbox to live	Before launch	Head of Compliance
5	Appoint a sanctions and PEP screening provider. Until then, check manually against the OFSI consolidated list at KYC approval and record the check in the review notes.	Launch	MLRO
6	Payments: move Stripe from test to live mode (the switch to GBP was made on 20 October 2026), configure Stripe Radar rules and 3-D Secure, and match the payout account holder's name to the KYC legal name	Launch	Head of Compliance / engineering
7	Set `EMAIL_ADMIN` and `SENTRY_DSN` in production, and confirm alerts arrive	Launch	Engineering
8	Confirm every staff account has 2FA enabled (enforced in production)	Launch	Head of Compliance
9	Set the AML and affordability thresholds (`AML_*`, `AFFORDABILITY_REVIEW_THRESHOLD_CENTS`) to the values in the approved risk assessment, in GBP pence	Launch	MLRO
10	Build automated data-retention purges matching the Privacy Policy	Within 3 months of launch	Engineering
11	Move rate limiting from per-process memory to Redis before running more than one web instance	Before scaling	Engineering

#	Item	Needed for	Owner
12	~~Add a Content-Security-Policy and frame-ancestors headers~~ Done 30 September 2026. Remaining: move to nonce-based CSP (Document 13).	Launch	Engineering
13	Update the website's licensing statement ("does not currently hold a gambling licence") to show the licence number once granted	On grant	Head of Compliance
14	Staff training programme and records	Launch	Head of Compliance
15	Engage the external compliance adviser for quarterly independent review	Launch	Board
16	Confirm the current Commission thresholds and rules on: financial vulnerability and affordability checks, consumer-set financial limit prompts, and marketing consent. Adjust the platform settings to match.	Application	Head of Compliance
17	Record the Railway region and backup location; confirm backups are enabled and test a restore	Application	Engineering
18	Decide permitted jurisdictions and add IP geolocation blocking plus a residency restriction at verification (Document 08 §6)	Launch	Head of Compliance / engineering
19	Engage a Commission-approved test house for RNG and game certification (Document 11 §3.1); confirm with the Commission the in-house/third-party split for peer-to-peer games (Higher / Lower withdrawn 30 Sep 2026 as mostly chance)	Application	Head of Compliance
20	Commission an independent penetration test; appoint the annual security auditor (first audit within 6 months of grant)	Launch / grant + 6 months	Head of Compliance
21	Close the information security gaps in Document 13 §6 (log retention, written staff security rules, supplier assurance, key rotation, `timestamptz`)	As marked there	Head of Compliance / engineering
22	Review the 12 January 2026 update to RTS 14 against Policies 03 and 04 (Document 12 §4)	Application	Head of Compliance
23	Build the monthly game-fairness statistical check from the game event log (Document 11 §6)	Launch	Engineering
24	Get Stripe's written approval for gambling (or appoint a gambling-approved PSP) and confirm its FCA reference number (Policy 16)	Launch	Head of Compliance
25	Block credit-funded cards on deposits (Policy 16 §7)	Launch	Head of Compliance / engineering

9. Version history

Version	Date	Author	Change
0.1	30 September 2026	[COMPLIANCE LEAD NAME]	First draft for licence application